Incident report analysis

Summary	An intern told the IT department that she could not log in to her account. The access logs showed that the account was still reading records in the customer database even though she was locked out. She had received an email that morning asking her to log in to an external website with her company credentials to read a message, so we believe her credentials were stolen by phishing. A few employees also noticed customer records that were missing or wrong, which means the attacker did not only read the data: some of it was deleted or changed. Identify, Protect and Detect below describe what the company changes after this incident to be better prepared. Respond and Recover describe how the incident itself is handled.
Govern	I would add a written access policy that says a password alone is never enough to reach customer data. It should also name who is responsible for reviewing who has access to the database and who runs the phishing training each year, so these tasks do not depend on someone remembering them.
Identify	The incident team reviewed the systems, devices and access policies involved. The gap was that a username and a password were enough to reach the customer database, and that employees were not trained to recognize a phishing email.
Protect	New authentication rules: multifactor authentication (MFA), a limit of three login attempts, and training for all employees on how to protect their credentials. The firewall configuration will also be improved and the company will invest in an intrusion prevention system (IPS).
Detect	A firewall logging tool and an intrusion detection system (IDS) will monitor the traffic coming from the internet, so unauthorized access attempts are noticed earlier.
Respond	The intern's account was disabled. Interns and employees received training on how to protect their login credentials. Upper management was informed, and they will write to the affected customers and contact law enforcement and any other body required by local laws.
Recover	The deleted data will be restored from last night's full backup. Anything entered or changed this morning is not in that backup, so

	staff were told they will have to enter it again after the restore.
Reflections/Notes	A stolen password should never be enough to get into customer data. The backup is what limited the damage here, so it needs to be recent and tested. What I learned here goes back into every function above, starting with Govern.